PrimusCredence

Provable Security

primuscredence.com

UAE

Dr. Raghavendra Ramesh

Founder & CEO, PrimusCredence

22+ YEARS OF EXPERIENCE IN PROVABLE SECURITY

PhD, IISc Bangalore
Model checking for information-flow security

Oracle Labs · 2014–2019
Java vulnerability detection

ConsenSys R&D · 2019–2021
Cross-chain protocols, consensus verification

Supra · VP of R&D · 2021–ongoing
BFT design & FV, bridges, DeFi & Crypto

TECHNIQUES

Static analysis, theorem proving, model checking

TOOLS

Dafny, TLA+, IVy, Lean, Isabelle

Where the Risk Actually Lives

The cloud base is proven. The app above it — and the seams between — are not.

Third-party plugins & extensions
Run inside the app — and inherit its privilege

APPLICATION

Its own roles, API tokens and public users — the authorisation logic and configuration in its database and admin panel

OWASP #1 Broken Access Control · #2 Misconfiguration — in 100% of apps

THE APP ↔ CLOUD & LIBRARY SEAM

- Access control via APIs
- SDK & library usage
- Network paths & zones

CLOUD & INFRASTRUCTURE

VMs · containers · databases · queues · object storage · IAM · network

Access control & network — proven: Zelkova, Tiros

UNPROVEN TODAY

Where the breaches are

The app's own access control, its plugins, and the API, library and network seams beneath it.

→ This is what we prove.

PROVEN BASE

Cloud IAM & network — already formally verified.

OWASP 2025 — Access Control & Misconfiguration

The two categories at the top are found in 100% of apps tested.

A01 Broken Access Control

#1 — unchanged

40 CWEs · 1.84M occurrences · 32,654 CVEs

SSRF now folded in — easy to exploit, widespread.

A02 Security Misconfiguration

#2 — up from #5

16 CWEs · 719,084 occurrences

Again, 100% of tested apps carried a form of it.

BROKEN ACCESS CONTROL IN THE WILD

Capital One	106M	WAF SSRF → over-privileged role; a tipster found it, ~4 months in
Optus	9.5M	access-control bug on a dormant, internet-facing API — latent ~4 years
T-Mobile	37M	API data retrieval without authorization — ~6 weeks to notice
Dell	49M	auto-approved fake partner, then service-tag enumeration
Trello	15M	unauthenticated email lookup through rotating proxies
Twilio Authy	33M	unauthenticated endpoint enumerated for phone numbers

All were authenticated requests — the flaw was what the policy allowed.

Segmentation Is Asserted, Not Proven

Once inside, lateral movement is the phase that turns an incident into a breach.

29 min
average breakout to the first lateral move (2025)

27 sec
the fastest breakout ever observed

82%
of intrusions were malware-free — valid access, not code

WHY PROBING CAN'T ANSWER IT

- Tests only the paths you thought of
- Can't tell blocked from about-to-change
- East-west is claimed more than shown

REACHABILITY IS A CONFIG PROPERTY

- Routes, SGs, NACLs, firewall rules
- Decided statically — no scanning window
- Precedent: AWS Tiros · Batfish

On an OT network probing is forbidden — the IT/OT boundary must be proven, not tested.

Apps Misuse the APIs They Run On

Cloud and app APIs are protocols, not calls — misuse still compiles.

THE PATTERN

- An object fetched by request ID with no ownership check — BOLA / IDOR
- A credential written to a log; pagination left undrained
- Authorisation in middleware a scanner can't see

THE TREND IS NOT REVERSING

+29% IDOR reports year on year (HackerOne 2025)

+36% access-control criticals — now #1 (Bugcrowd 2025)

~95% of API attacks carry a valid token — authentic, not authorised

$4.4M
average cost of a data breach (IBM 2025)

241 days
mean time to identify and contain (IBM 2025)

258 / day
API attacks per enterprise — 2× 2024 (Akamai 2025)

A correct policy invoked through a misused SDK still leaks.

AI Industrialises the Attacker

Point-in-time testing cannot keep pace with an enumerating attack.

4.5×
revenue of AI-assisted scam operations versus non-AI equivalents

$3.52
average compute cost per LLM-agent exploit attempt on a real CVE

87%
of a 15-CVE sample exploited from the public description alone

TRADITIONAL PEN TEST

10^2–10^3 paths, human-selected
2–4 week window, then closed
High marginal cost per path
“We found no way in”

AI-DRIVEN ADVERSARY

10^5–10^7 paths, machine-enumerated
Continuous, no window
Near-zero marginal cost
Approaching exhaustive

Proof is the one capability that answers exhaustive search in kind.

What Today's Security Stack Leaves Open

Each tool answers its own question well. One question stays open.

SAST / DAST / IAST · SCA / supply chain · ASPM · WAF / API security · CSPM · CIEM · CNAPP · Pen test & red team · SOC · EDR · SIEM · Policy-as-code

- **SAST** — Knows code patterns, not intent. A check present but wrong still passes.
- **DAST** — Tests the endpoints and personas it is given — not every user × object.
- **IAST / RASP** — Same-code-path BOLA is invisible — was the call even permitted?
- **SCA / ASPM** — Known CVEs and risk diffs; never whether a grant is actually correct.
- **CNAPP / CSPM** — Stops at the cloud IAM role; never reads the app's own roles.
- **WAF / API sec** — Judges traffic, not grants: whether it should be permitted is upstream.

They all share one gap: no statement of what is allowed, decided over every request.
Keep every one of them — and add the layer that closes that gap.

Proof — Now Feasible

Formal verification used to take expert teams years. AI brings it into range.

THEN

- Expert teams, bespoke specs, years
- Confined to avionics, silicon, protocols
- “End users won’t write a spec”

NOW — AI-ASSISTED

- AI assists modelling & proof search
- Expert owns & ratifies the spec
- AWS runs ~1B SMT queries a day

What we add A preventive control with evidence behind it, beside your testing and SOC.
We add to your stack; we don’t replace it. Proof alone isn’t enough.

WHAT STAYS WITH YOU — ALL OF IT NEEDED

Configuration drift, shadow assets and anything outside the model

Insider misuse, and valid credentials used exactly as intended

Detection, response and the rest of the programme you already run

Automated Reasoning

Proof establishes that bad things cannot happen.

1. **Formalise** — Your existing artefact becomes a logical model
2. **State** — The bad state you fear becomes a formula
3. **Solve** — Z3, Batfish, IVy, TLA+ decide it; CBMC to a bound
4. **Report** — A proof, or a reproducible attack path

✦ AI-POWERED ✦

UNSAT

No violating state exists — over the entire space, under a stated model.
Not “none was found”.

SAT + witness

The exact request, path or call ordering that breaks it — reproducible on your estate.

Not every property is decidable, and a proof holds only for the property and model stated.
Industrial practice: AWS · Microsoft · Meta · Airbus.

Services

One method — three services: access control, network isolation, API protocols.

1

ACCESS CONTROL

App entitlement proofs

Every app role, API token and public user — decided over all requests.

Who can reach what?

2

NETWORK ISOLATION

Network segmentation

Routes, security groups and firewall rules — every path between zones.

Any path across zones?

3

API PROTOCOLS

App & API conformance

Cloud, credential and data-access SDKs — used as their contracts require.

SDKs used correctly?

1. Application Access-Policy & Entitlement Verification

> *What can each app role, API token and public user do inside the app — and can any of them reach what they should not?*

THE PROBLEM

An app's authorisation lives in its own database and admin panel — which role reads which type, what the Public role exposes. No SAST, CSPM or CNAPP reads it; DAST only samples.

Portable: it reads the app's own config, so it holds on-prem, not only in cloud.

PRECEDENT Cedar + SymCC → Cedar Analysis

BUYERS Platform & AppSec teams · ISVs

WHAT WE BUILD

- The app's roles, API tokens and public users, into Cedar
- SymCC decides over all requests — BOLA, BFLA, BOPLA
- CheckNoNewAccess gates every admin policy change

OUTPUT Proof that no role, token or public user reaches what it must not — over all requests — or the exact request that breaks it.

2. Network Reachability & Segmentation Proofs

> *Does any path exist from an untrusted zone to this subnet — and does east-west segmentation actually hold?*

THE PROBLEM

Probing tests the paths you thought of, when you ran it. Reachability is a property of the configuration — routes, security groups, firewall rules — not of the packets you send.

No scanning window, no production traffic — it re-runs on every change.

PRECEDENT AWS Tiros → VPC Reachability Analyzer

BUYERS Regulated finance · OT & critical infra · sovereign cloud

WHAT WE BUILD

- Hybrid and on-prem estate modelled with Batfish
- Soufflé and Z3 over the cloud topology, statically
- Microsegmentation checked against the declared policy

OUTPUT A proof that no path exists — or the path, hop by hop, with the rule that permits it and the owner of that rule.

3. Application and API-Usage Conformance

> *Does our own code use the APIs it is built on — cloud, credential and crypto SDKs, and its own data-access calls — the way their contracts*

THE PROBLEM

Cloud and app APIs are protocols, not calls. Undrained pagination, a logged credential, an object fetched by request ID without an ownership check — all compile and pass review. Same risk

A correct policy invoked through a misused SDK still leaks. Bounded by the library.

PRECEDENT AWS RAPID → CodeGuru · 76% accepted

BUYERS Platform and AppSec teams · ISVs

WHAT WE BUILD

- Object-ownership (BOLA/IDOR) and auth-routing patterns
- A conformance gate for library publishers
- PR-gate CI on Soot, CodeQL and Infer

OUTPUT The call site, the taint trace, the pattern violated and the corrected call sequence — plus which patterns were checked.

Our Approach

We partner with cybersecurity solutions providers, adding provable assurance.

HOW WE PARTNER — THROUGH THE PROVIDERS

Provable control effectiveness inside their bids.

They keep the client relationship and the contract.

We don't certify — a channel, not a rival.

WHOM WE REACH THROUGH THEM — THE GCC CLIENT BASE

Government & sovereign	UAE Digital Govt · Smart Dubai · Abu Dhabi Govt
Aviation & CNI	dans · air navigation · DEWA · Regional utilities
Energy, oil & gas	ADNOC · Aramco · OT operators
Banking & finance	Regional banks · Sovereign wealth funds · FinTechs
Telecom & cloud	e& · Etisalat · Core42 · G42 · STC Cloud

Why the Provider's Clients Will Ask

Four things happened at once in the GCC — and their clients feel all four.

Mandatory replaced voluntary

UAE cyber-resilience obligations now carry penalties of AED 100k–3m.

Assurance shifted to evidence

Regulators increasingly ask for demonstrable control effectiveness, not attestation.

Third-party risk is now in scope

Rules increasingly require evidence that integrations and components are controlled.

Sovereignty is a reachability question

Localisation asks whether regulated data can leave — our reachability proofs settle it.

WHERE A FINDING ALSO LANDS

DESC ISR	1 2 3	NESA / UAE IAS	2	UAE PDPL	2 3
SAMA CSF	1 2 3	NCA ECC	1 2 3	PCI DSS 4.0	1 2 3
ISO 27001	1 2 3	CIS Controls	1 2 3	NIST CSF 2.0	1–3

Regulation routes the finding to a second reader. It is not the reason to commission it.

What a Provider Can Resell

We do not certify — so an audit firm or an MSSP is a channel, not a rival.

Detection · response · posture reporting **+** **Provable control effectiveness**

THE COMMERCIAL MOVE

- Specialist capability inside bids you already win
- You keep the client relationship and the contract

WHY IT DEPLOYS EASILY

- Read-only access, no agent on any host
- No scanning window, no production traffic

Read-only and agentless, so it clears change advisory in one pass.

We produce the technical evidence. Your assessor keeps the opinion.

One Result, Three Registers

First line

Engineering and security operations

The property, its model and assumptions, and either the proof or a reproducible attack path.

Second line

Risk

Likelihood moved off a qualitative guess, with residual risk and the model's limits stated.

Third line

Internal audit and compliance

A clause-mapped control assertion: objective, status, owner and re-verification date.

✓ Design → operating effectiveness · attaches to your GRC records · assessors probe less

The first register is the product. The second and third make it worth more than it cost.

Take Away

Mathematical rigour to security —
proof alongside testing, across apps and AI.

The shift

Attack path discovery is automated, parallel and cheap. Detection shows what is happening; proof shows what cannot happen.

The addition

We do not replace testing, monitoring or the SOC. We make one class of controls machine checkable.

The honesty

A proof is relative to a model and a specification — both stated. We produce the evidence; we do not certify.

START HERE — MICRO ASSESSMENT OF SERVICE 1

One narrow, high-risk slice. Read-only access, no agent deployed, weeks not months — and a counter-example on your own systems, or a proof.

Thank You

primuscredence.com

Dr. Raghavendra Ramesh
Founder & CEO, PrimusCredence
PhD, IISc Bangalore

raghavendra@primuscredence.com
+971 58 189 2803
UAE

Provable Security for Applications